

DOC-003: DATA CLASSIFICATION ASSESSMENT & GOVERNANCE COMPLIANCE

UFOSI — Universal Financing Optimized Syariah Intelligent-assistant

A. METADATA & GOVERNANCE CONTROL

Parameter Tata Kelola	Deskripsi & Identifikasi Dokumen
Kode Dokumentasi	DOC-003
Fase Tata Kelola	Data Architecture Phase — SDLC Mapping: Information Security, Privacy & Risk Compliance
Versi Master	v1.2.0 — Updated: 05 June 2026
Status Dokumen	[v] Draft [] Under Review [] Approved

B. ACCOUNTABILITY & READINESS MATRIX

Peran Tata Kelola	Aktor / Pemangku Kepentingan	Uraian Tanggung Jawab Operasional & Kesiapan
Document Owner	Infrastructure Security Lead / Risk Management Stream	Bertanggung jawab mengaudit akurasi penetapan label kerahasiaan data, menetapkan batasan kebijakan penanganan informasi siber, serta memastikan kontrol enkripsi di tingkat storage mematuhi regulasi eksternal perbankan seperti OJK, Bank Indonesia, dan UU Pelindungan Data Pribadi.
Target User Input	Lead Developer / Dev Stream	Wajib mengidentifikasi secara detail seluruh skema objek data, struktur berkas finansial, metadata antrean, struktur logs, credential dependency, dan data yang mengalir di dalam runtime container UFOSI.
Application Owner / Business Analyst	Tim Pembiayaan SME / Business Analyst	Membantu memberikan justifikasi ruang lingkup operasional data bisnis finansial nasabah SME dari sisi kebutuhan bisnis, kepatuhan perbankan syariah, serta validasi sensitivitas informasi yang diproses oleh aplikasi.
IT Operations Team	IT Operations / Infrastructure Team	Bertanggung jawab memastikan kontrol teknis seperti pembatasan akses namespace, backup database, pengamanan folder upload, sanitasi log, monitoring, dan evidence operasional diterapkan sesuai klasifikasi data.
IT Security / Risk Compliance	Security & Risk Compliance Stream	Bertanggung jawab melakukan review risiko data, rekomendasi masking/anonymization, validasi exposure network, serta memastikan data dummy digunakan pada fase UAT dan Demo Day.

C. STRATEGIC PURPOSE / TUJUAN OPERASIONAL

Dokumen ini ditujukan sebagai instrumen tata kelola dan kepatuhan formal dalam mengidentifikasi, mengklasifikasikan, dan menetapkan batasan perimeter proteksi keamanan terhadap seluruh informasi yang diolah oleh sistem UFOSI atau Universal Financing Optimized Syariah Intelligent-assistant di lingkungan Bank Syariah Indonesia.

UFOSI melakukan pemrosesan otomatis berbasis AI parsing terhadap dokumen sensitif berupa rekening koran pembiayaan SME. Oleh karena itu, penilaian risiko klasifikasi data menjadi hal yang wajib dilakukan sejak fase awal proyek agar seluruh stakeholder memahami jenis data yang diproses, tingkat kerahasiaannya, potensi dampak kebocoran, serta kontrol keamanan minimum yang harus diterapkan.

Penyusunan dokumen ini bertujuan untuk memitigasi risiko kebocoran data rahasia perbankan, mengatur hak akses operasional berdasarkan prinsip Least Privilege Data Access, menentukan mekanisme manipulasi data aman seperti Data Masking dan Anonymization, serta memastikan seluruh data yang digunakan pada fase pengembangan 5 hari dan Demo Day tidak mengekspos informasi nasabah riil.

D. CONTENTS & DATA TAXONOMY ASSESSMENT

Risk, Security & Dev Input

Bagian ini wajib dievaluasi dan diisi secara komprehensif oleh perwakilan stream terkait, khususnya Risk, Security, Developer, Business Analyst, dan IT Operations.

1. Kuesioner Penilaian Karakteristik Data — Data Element Identification

Mohon lakukan analisis mendalam terhadap objek data yang disentuh oleh sistem UFOSI.

Pertanyaan Identifikasi Kompatibilitas Data	Justifikasi Teknis & Konfirmasi Proyek UFOSI
Apakah aplikasi mengolah PII / Personally Identifiable Information Debitur?	[v] YA [] TIDAK Identifikasi Elemen: Sistem membaca dan/atau memproses nama pemilik usaha, nama badan usaha, nomor rekening BSI atau bank lain, nomor dokumen legalitas seperti NIB/NPWP, alamat operasional bisnis, informasi kontak personel SME, serta data identitas pendukung yang dapat mengarah kepada identifikasi nasabah atau calon debitur.
Apakah aplikasi mengolah Data Keuangan Komersial Sensitif / Financial Data?	[v] YA [] TIDAK Identifikasi Elemen: Sistem mengurai riwayat mutasi rekening berupa debit/kredit, saldo akhir bulanan, tren perputaran kas atau cashflow, nominal omzet penjualan, pola transaksi masuk dan keluar, indikasi pembiayaan eksisting, serta data pendukung analisis kelayakan finansial SME.
Apakah aplikasi mengolah Kredensial, Token, atau Informasi Rahasia Sistem / Credential Data?	[v] YA [] TIDAK Identifikasi Elemen: Aplikasi menggunakan credential database PostgreSQL, secret environment variable, token autentikasi session atau JWT jika tersedia, API key komunikasi antar-service, konfigurasi koneksi internal container, serta informasi teknis yang tidak boleh terekspos pada log publik maupun repositori terbuka.
Apakah aplikasi terhubung atau mengolah Data Medis / Kesehatan / Healthcare Data?	[] YA [v] TIDAK Justifikasi: Ruang lingkup fungsionalitas UFOSI murni terbatas pada optimalisasi analisis pembiayaan komersial SME syariah. Sistem tidak dirancang untuk menerima, memproses, menyimpan, atau menganalisis data medis, rekam kesehatan, diagnosis, asuransi kesehatan, maupun informasi klinis lainnya.
Apakah aplikasi mengolah dokumen legalitas usaha?	[v] YA [] TIDAK Identifikasi Elemen: Pada konteks pembiayaan SME, sistem berpotensi membaca dokumen pendukung seperti NIB, NPWP, informasi legalitas usaha, nama perusahaan, alamat usaha, dan data administratif lain yang mendukung proses validasi dokumen pembiayaan.
Apakah aplikasi menyimpan hasil analisis atau scoring pembiayaan?	[v] YA [] TIDAK Identifikasi Elemen: Sistem menghasilkan output berupa hasil ekstraksi, ringkasan transaksi, indikator cashflow, kesimpulan analisis awal, dan/atau rekomendasi pendukung pengambilan keputusan. Data ini dikategorikan sensitif karena berkaitan dengan proses internal analisis pembiayaan.
Apakah aplikasi menghasilkan log operasional dan teknis?	[v] YA [] TIDAK Identifikasi Elemen: Runtime container menghasilkan application logs, API request logs, stdout/stderr container logs, healthcheck logs, error trace, dan monitoring metrics. Log wajib disanitasi agar tidak memuat data nasabah, file asli, token, password, atau hasil ekstraksi sensitif.

2. Matriks Penilaian Level Kerahasiaan Objek Data UFOSI — Data Lifecycle Classification

Objek Elemen Data	Level Klasifikasi Terpilih	Analisis Dampak Kerugian Korporasi Jika Data Bocor
File Dokumen PDF Rekening Koran Asli Nasabah SME	[] Public [] Internal [] Confidential [v] Restricted	Sangat Fatal / Krisis Kepatuhan. Kebocoran file rekening koran asli dapat melanggar prinsip kerahasiaan bank, memicu risiko hukum berdasarkan regulasi perlindungan data pribadi, menimbulkan sanksi regulator, merusak reputasi BSI, serta menghilangkan kepercayaan nasabah terhadap pengelolaan informasi finansial.

Hasil Ekstraksi & Parsing JSON Berbasis AI Engine	☐ Public ☐ Internal ☒ Confidential ☐ Restricted	Tinggi / Kerugian Informasi Bisnis dan Analitik. Data hasil parsing dapat menampilkan ringkasan transaksi, pola cashflow, indikator kelayakan, skor pembiayaan, serta formula atau pendekatan analisis internal. Jika bocor, data ini dapat mengungkap proses pengambilan keputusan dan informasi finansial calon debitur.
Dokumen Berkas Rekening Koran / SLIK Simulasi Dummy untuk UAT & Demo Day	☐ Public ☒ Internal ☐ Confidential ☐ Restricted	Rendah-Sedang. Data dummy tidak merepresentasikan nasabah riil, namun tetap tidak boleh didistribusikan secara bebas karena berhubungan dengan skenario internal, struktur analisis, dan alur demonstrasi sistem UFOSI. Akses tetap dibatasi untuk tim proyek dan pihak penguji internal.
System App Logs & Kontainer Docker stdout Trace	☐ Public ☒ Internal ☐ Confidential ☐ Restricted	Sedang / Kebocoran Teknis. Log dapat mengekspos struktur API, query database, nama tabel, pesan error, path internal container, dependency service, atau potensi kelemahan exception handling. Oleh karena itu, log harus dibatasi aksesnya dan tidak boleh memuat data sensitif.
Database PostgreSQL UFOSI	☐ Public ☐ Internal ☐ Confidential ☒ Restricted	Sangat Fatal. Database berpotensi menyimpan metadata dokumen, hasil ekstraksi, akun aplikasi, konfigurasi, dan hasil analisis. Kebocoran database dapat menyebabkan eksposur data secara masif dan berdampak langsung pada kepatuhan, reputasi, serta keamanan operasional.
Environment Variable, Secret, Password Database, dan API Key	☐ Public ☐ Internal ☐ Confidential ☒ Restricted	Sangat Fatal / Kompromi Sistem. Jika credential bocor, pihak tidak sah dapat memperoleh akses ke database, service internal, container runtime, atau API aplikasi. Dampaknya dapat berupa data breach, perubahan data, service takeover, dan eskalasi akses.
File Upload Temporary dan Hasil OCR Sementara	☐ Public ☐ Internal ☐ Confidential ☒ Restricted	Tinggi-Sangat Fatal. Folder upload dan hasil OCR sementara dapat berisi dokumen asli atau potongan hasil ekstraksi yang memuat data finansial nasabah. Data wajib dihapus setelah proses selesai atau setelah melewati masa retensi yang disetujui.
Monitoring Metrics Prometheus / Dashboard Grafana	☐ Public ☒ Internal ☐ Confidential ☐ Restricted	Sedang. Metrics umumnya tidak berisi data nasabah, tetapi dapat memperlihatkan struktur service, nama namespace, endpoint, status pod, penggunaan resource, dan indikasi arsitektur internal. Dashboard hanya boleh diakses oleh tim operasional dan stakeholder teknis terkait.
Backup Database dan Evidence Operasional	☐ Public ☐ Internal ☐ Confidential ☒ Restricted	Sangat Fatal. Backup dapat berisi salinan lengkap database dan konfigurasi sistem. Evidence operasional juga dapat berisi output command, nama service, konfigurasi endpoint, atau potongan log. Penyimpanan dan distribusinya harus sangat dibatasi.

3. Kebijakan Manajemen & Kontrol Keamanan Informasi — Data Security Control Matrix

Berdasarkan tingkat klasifikasi di atas, tim pengembang dan tim operasional wajib menegakkan aturan proteksi minimum berikut.

Level Klasifikasi	Kontrol Penyimpanan / Data at Rest	Kontrol Pengiriman / Data in Transit	Aturan Masking & Retensi / Data Sanitization
Public	Tidak membutuhkan kontrol khusus selain menjaga integritas file dan dokumentasi.	Dapat dikirim melalui kanal komunikasi umum yang disetujui organisasi.	Tidak membutuhkan masking. Retensi mengikuti kebutuhan dokumentasi umum proyek.
Internal	Pembatasan izin akses folder tingkat OS menggunakan Linux permission dan Linux ACL standard. Akses hanya untuk tim internal proyek.	Isolasi jaringan lokal melalui internal network, Docker bridge network, Kubernetes service network, atau intranet internal.	Tidak membutuhkan masking penuh. Berkas internal pengujian dihapus otomatis atau manual maksimal 7 hari setelah evaluasi tugas selesai.
Confidential	Enkripsi pada kolom database yang memuat nilai finansial atau informasi sensitif. Secret tidak boleh ditulis hardcoded di source code. Akses database dibatasi berdasarkan role.	Wajib menggunakan komunikasi terenkripsi seperti HTTPS/TLS untuk akses aplikasi yang melewati jaringan antar-host. Untuk komunikasi internal demo, akses dibatasi pada	Informasi skor pembiayaan, ringkasan keuangan, nomor rekening, dan nama debitur dimasking sebagian pada UI, log, dan dokumen presentasi. Data tidak boleh digunakan di screenshot publik.

		network internal yang terkontrol.	
Restricted	Enkripsi volume penyimpanan atau proteksi storage yang ketat. Backup database disimpan di lokasi terbatas. Secret, token, dan credential dikelola sebagai restricted data. Folder upload dibatasi hanya untuk service terkait.	Wajib menggunakan secure VPN, IP whitelisting, network segmentation, dan pembatasan akses hanya dari workstation atau jaringan internal yang disetujui. Tidak boleh internet-facing.	Data nama nasabah riil, rekening koran asli, nomor rekening, token, password, dan dokumen asli wajib disamarkan atau tidak digunakan saat demo. Dokumen asli dipurge dari folder upload setelah proses ekstraksi selesai atau sesuai kebijakan retensi.

4. Aturan Data Masking, Anonymization, dan Demo Day

Area	Ketentuan Kontrol
Data Demo	Demo Day wajib menggunakan dummy data, synthetic data, atau data yang telah dianonimkan. Tidak diperbolehkan menggunakan dokumen rekening koran asli nasabah riil.
Nama Nasabah / Debitur	Nama nasabah diganti dengan identitas dummy seperti "PT Contoh Usaha Syariah" atau "Nasabah SME Dummy 001".
Nomor Rekening	Nomor rekening dimasking sebagian, contoh: 1234-****-****-7890.
Nominal Transaksi	Nominal dapat disesuaikan atau digeneralisasi agar tidak merepresentasikan transaksi riil.
Dokumen Upload	File asli tidak boleh tersimpan permanen di folder upload. File temporary wajib dihapus setelah proses parsing selesai atau setelah proses UAT selesai.
Screenshot Evidence	Screenshot untuk presentasi tidak boleh menampilkan data pribadi, nomor rekening lengkap, token, password, secret, atau isi dokumen asli.
Log Aplikasi	Log tidak boleh mencetak payload dokumen, isi file, credential, JWT, password database, atau hasil OCR lengkap.
Output AI/OCR	Output hasil parsing yang digunakan untuk demo wajib dipastikan berasal dari data dummy atau sudah dianonimkan.

5. Data Retention Policy

Jenis Data	Retensi yang Direkomendasikan	Catatan
File PDF rekening koran asli	Dihapus segera setelah proses ekstraksi selesai atau maksimal 1x24 jam untuk kebutuhan debugging terbatas.	Untuk fase demo, sebaiknya tidak menggunakan data asli.
File dummy UAT / Demo Day	Maksimal 7 hari setelah evaluasi selesai.	Dapat disimpan lebih lama hanya jika diperlukan untuk dokumentasi internal dan sudah disetujui.
Hasil ekstraksi JSON	Maksimal selama periode UAT atau sesuai kebutuhan validasi.	Harus dimasking jika mengandung data sensitif.
Database backup	Disimpan sesuai kebutuhan recovery proyek dan aksesnya dibatasi.	Backup sebelum maintenance/deployment disimpan di folder evidence terbatas.
Application logs	7–14 hari untuk kebutuhan troubleshooting demo/staging.	Wajib disanitasi dari PII dan credential.
Monitoring metrics	14–30 hari untuk analisis performa staging.	Tidak boleh memuat payload dokumen atau informasi nasabah.
Secret dan credential	Berlaku selama environment aktif dan harus dirotasi jika terjadi exposure.	Tidak boleh disimpan di file dokumentasi publik atau screenshot.

6. Data Access Control & Least Privilege

Role / Tim	Hak Akses yang Diizinkan	Batasan
IT Operations	Akses ke deployment, namespace, service, pod logs terbatas, backup teknis, monitoring, dan evidence operasional.	Tidak boleh membuka isi dokumen nasabah kecuali untuk debugging terbatas dengan approval.
Developer Team	Akses ke application code, endpoint, schema data, log aplikasi yang sudah disanitasi, dan environment staging.	Tidak boleh menyimpan credential di source code atau membagikan data nasabah melalui kanal tidak resmi.
IT Security / Risk	Akses review terhadap kontrol keamanan, konfigurasi akses, klasifikasi data, dan bukti sanitasi data.	Tidak melakukan perubahan langsung pada data aplikasi tanpa koordinasi.
Business Analyst / Application Owner	Akses terhadap output analisis, skenario UAT, dan validasi kebutuhan bisnis.	Tidak memiliki akses langsung ke credential, database backend, atau

		konfigurasi infrastruktur.
Project Manager	Akses ke status readiness, timeline, risiko, dan evidence non-sensitif.	Tidak membutuhkan akses ke data mentah, credential, atau database.
Penguji / Manajemen Demo	Akses hanya ke tampilan demo dan dokumen presentasi yang sudah menggunakan data dummy.	Tidak boleh menerima file asli, backup, secret, atau log teknis mentah.

7. Risiko Data & Mitigasi

Risiko	Dampak	Mitigasi
Dokumen rekening koran asli digunakan saat demo	Risiko kebocoran data nasabah dan pelanggaran kepatuhan.	Gunakan dummy data atau data yang telah dianonimkan sepenuhnya.
Log aplikasi mencetak payload sensitif	Data rekening, hasil OCR, atau credential terekspos.	Terapkan log sanitization dan nonaktifkan debug log pada sesi demo.
Password database tersimpan hardcoded	Risiko kompromi database.	Gunakan environment variable, secret management, dan pembatasan akses file konfigurasi.
Folder upload tidak dibersihkan	File sensitif tertinggal di server.	Terapkan purge otomatis atau prosedur manual setelah ekstraksi selesai.
Backup database disimpan tanpa pembatasan akses	Data breach melalui file backup.	Simpan backup di folder terbatas, batasi akses OS, dan hindari distribusi backup mentah.
Monitoring dashboard terbuka untuk semua user	Struktur sistem dan metrics internal terekspos.	Gunakan autentikasi Grafana, batasi port akses, dan gunakan jaringan internal.
Screenshot evidence menampilkan informasi sensitif	Kebocoran melalui dokumen presentasi.	Review semua screenshot sebelum dimasukkan ke laporan atau slide.

8. Minimum Security Requirement untuk UFOSI

Area Kontrol	Requirement Minimum
Network Exposure	Aplikasi tidak boleh internet-facing. Akses hanya melalui intranet, secure VPN, atau jaringan internal yang disetujui.
Authentication	Akses dashboard, aplikasi, database, dan monitoring wajib menggunakan kredensial yang tidak dibagikan secara publik.
Authorization	Hak akses diberikan berdasarkan role dan kebutuhan kerja.
Secret Handling	Password, token, API key, dan connection string tidak boleh muncul di source code, screenshot, log, atau dokumen publik.
Database Protection	Database PostgreSQL harus dibatasi aksesnya hanya dari service yang membutuhkan.
Log Protection	Log harus disanitasi dari PII, data finansial, token, password, dan isi dokumen.
Backup Protection	Backup database hanya boleh diakses oleh IT Operations yang berwenang.
Demo Protection	Demo wajib menggunakan dummy data atau anonymized data.
Evidence Protection	Evidence operasional harus dipilah antara evidence teknis aman dan evidence yang mengandung data sensitif.
Retention	File temporary dan log sensitif harus dihapus sesuai masa retensi.

9. Kesimpulan Penilaian Klasifikasi Data

Berdasarkan identifikasi data yang diproses oleh UFOSI, sistem ini termasuk aplikasi dengan risiko data tinggi karena berhubungan dengan dokumen rekening koran, data finansial SME, informasi identitas debitur, hasil parsing AI, serta credential teknis aplikasi.

Objek data paling sensitif adalah file rekening koran asli, database PostgreSQL, file upload temporary, backup database, credential, token, dan secret aplikasi. Objek tersebut dikategorikan sebagai Restricted karena kebocorannya dapat berdampak pada pelanggaran kerahasiaan perbankan, risiko regulasi, kerugian reputasi, serta potensi kompromi sistem.

Untuk fase pengembangan 5 hari dan Demo Day, UFOSI wajib menggunakan data dummy atau data yang telah dianonimkan. Tim IT Operations, Developer, Business Analyst, Security, dan Project Manager harus memastikan tidak ada data nasabah riil, nomor rekening lengkap, credential, atau payload sensitif yang muncul pada UI demo, log, screenshot, evidence, maupun dokumen presentasi.

Dengan demikian, dokumen DOC-003 ini menjadi dasar tata kelola klasifikasi data, kontrol keamanan, masking, retensi, dan pembatasan akses terhadap seluruh data yang diproses oleh sistem UFOSI.